



MT05 · Auth mínima defensible

L'autenticació no és el producte: **protegeix una acció del producte.**

R2S5 · R2S6

60 MIN

Auth protegeix una operació real

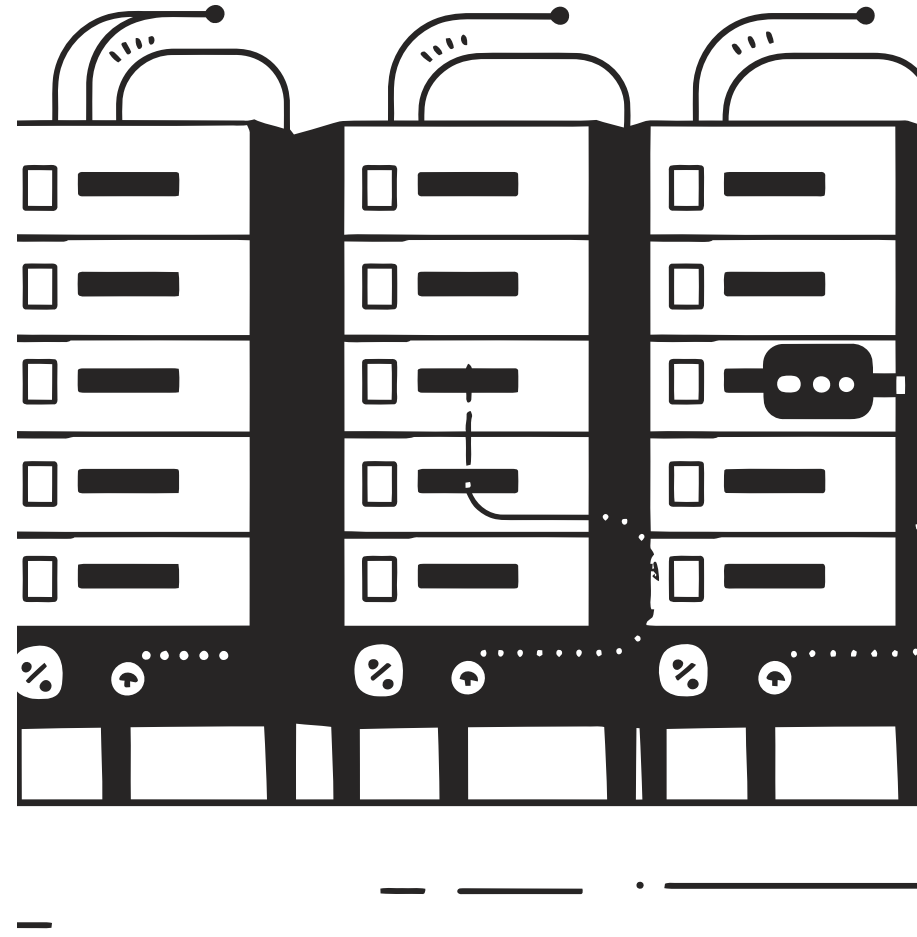
✗ Sense auth

Qualsevol crida a `/api/orders` funciona

✓ Amb auth

Només l'usuari identificat i autoritzat accedeix

❗ El login per si sol no és evidència. La protecció real viu al backend, no a la pantalla.



Tres preguntes clau

1

Qui eres?

Autenticació — identificar l'usuari

2

Què vols fer?

Acció — l'operació sol·licitada

3

Tens permís?

Autorització — validar el rol o dret

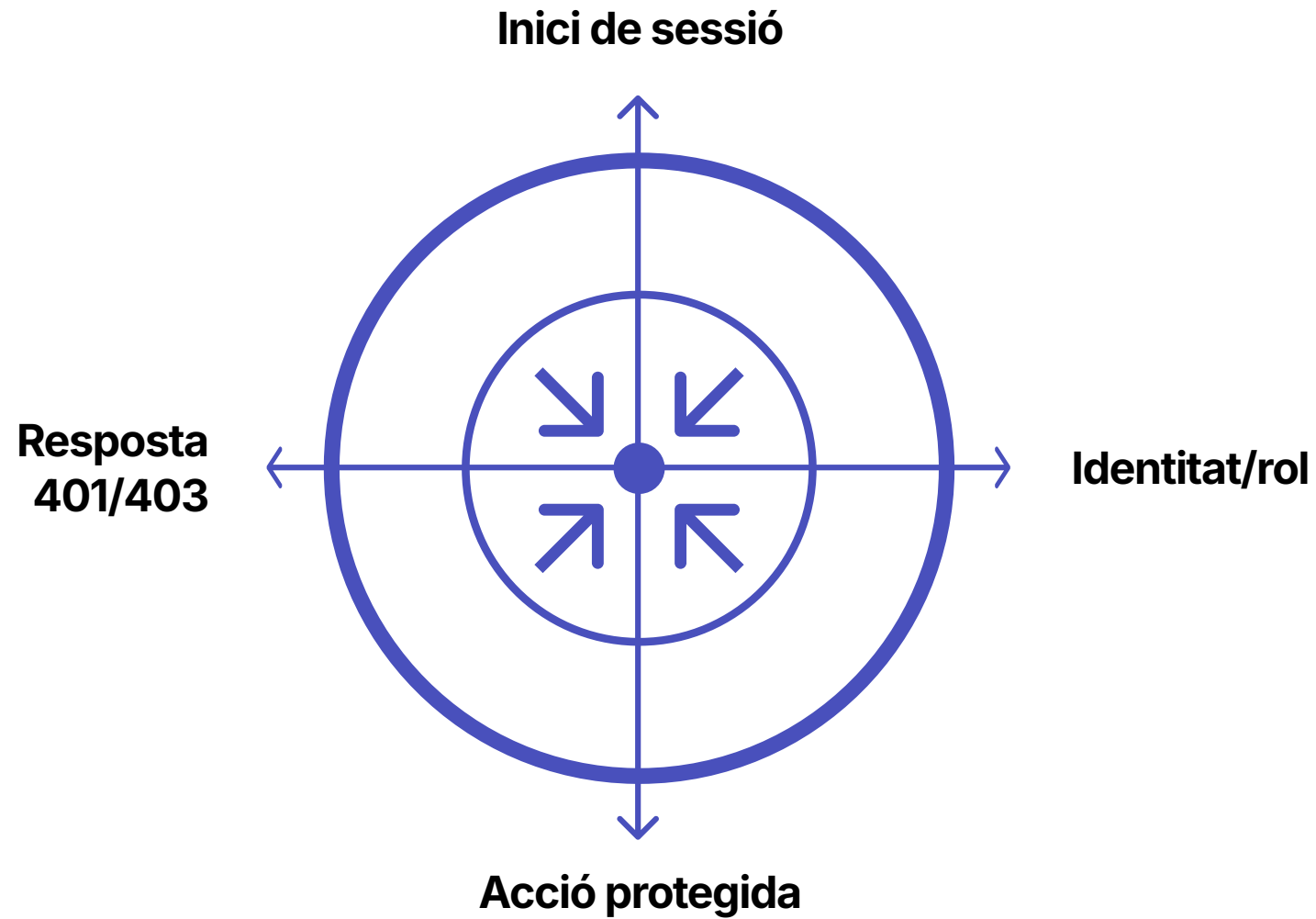
Autenticació

Confirma *qui* fa la petició. Exemples: sessió, token, cookie.

Autorització

Decideix *si pot* fer-ho. Exemples: rol `admin`, propietari del recurs.

El mínim defensable



Sense algun d'aquests quatre elements, la protecció és incompleta.

Errors habituals

Pantalla decorativa

El formulari de login existeix però el backend no comprova res.

Permisos al frontend

Amagar botons no és protecció. Cal validar al servidor.

Provar només el cas correcte

Si no pots ensenyar el cas denegat, la protecció és feble.



Evidència del dia

Quatre elements que cal poder mostrar al final de la sessió:

01

Acció protegida

Un endpoint real que fa alguna cosa: crear, esborrar, modificar.

03

Cas denegat ❌

Petició sense sessió o sense permís → resposta 401 o 403.

02

Cas autoritzat ✅

Petició amb sessió o token vàlid → resposta 200.

04

Codi + README

Línia on es comprova l'accés localitzada i explicada al README.



Pregunta de tancament: **Què impedeix ara el backend que abans no impedia?**